

Information Technology Security Policy

IT Security Policy

Document No.	HR-IT-002
Version	3.0
Effective Date	1 January 2026
Policy Owner	Information Technology Department, jointly with Human Resources
Approved By	Chief Information Officer (CIO)
Review Cycle	Every 12 months, or upon identification of a significant new risk

1. Purpose

This policy establishes the standards and practices for information security at Example Business Public Company Limited to protect information assets, business data, and personal data from risks of unauthorised access, leakage, loss, or cyber-attack, in alignment with international standards such as ISO/IEC 27001 and the Computer-Related Crime Act.

2. Scope

This policy applies to employees, executives, contractors, and any external party who accesses or uses the Company's information systems, computer equipment, network, or data, whether working on-site or off-site.

3. Definitions

Term	Meaning
Information Assets	All hardware, software, data, and network systems owned or used by the Company
User	Any individual authorised to access the Company's information systems
Security Incident	An event that may compromise the confidentiality, integrity, or availability of data
Malware	Software designed to cause damage or to gain unauthorised access to a system

4. Information Security Principles

The Company adheres to three fundamental principles in managing information security:

- Confidentiality — data is accessible only to those authorised to access it

- Integrity — data must not be altered or modified without authorisation
- Availability — systems and data must be available when needed

5. Access Control

The Company sets the following standards for controlling access to information systems:

- Access is granted according to the Principle of Least Privilege
- Passwords must be at least 12 characters long, containing uppercase, lowercase, numeric, and special characters
- Multi-Factor Authentication (MFA) is mandatory for critical systems and external access
- Passwords must be changed every 90 days and may not repeat any of the last 5 passwords used
- User accounts are automatically locked after 5 consecutive failed login attempts
- User access rights are reviewed quarterly and revoked immediately upon an employee's separation

6. Acceptable Use of Equipment and Information Assets

- Company computer equipment must not be used for any illegal or unethical activity
- Unauthorised external storage devices (USB) must not be connected to Company computers
- Use of personal devices to access Company data (BYOD) requires prior approval and installation of approved device-management software
- Computer screens must be locked whenever the user steps away from the device

7. Malware and Virus Protection

All computer equipment must have anti-malware software approved by the IT Department installed, with virus definitions updated regularly. Such software must not be disabled or uninstalled without authorisation. If malware is detected, the user must immediately disconnect the device from the network and notify the IT Department as soon as possible.

8. Data Encryption

Sensitive or confidential data must be encrypted both at rest and in transit over the network, using recognised encryption standards such as AES-256 and TLS 1.2 or higher. Portable devices, such as laptops and external hard drives, must have full-disk encryption enabled.

9. Backup and Disaster Recovery

The IT Department must ensure that critical systems are backed up daily, with backup copies stored in a location separate from the primary system. The Company must maintain a Business Continuity Plan and Disaster Recovery Plan, and test their readiness at least once a year.

10. Vulnerability and Patch Management

All operating systems and software must have security patches installed according to the schedule set by the IT Department. Critical vulnerabilities must be remediated within 7 days of patch release, and a Vulnerability Assessment of systems must be conducted at least twice a year.

11. Internet and Email Use

- Do not open attachments or click links in emails that are untrustworthy or suspected of being phishing attempts
- Do not send confidential Company data via personal email accounts or unauthorised channels
- Access to websites deemed a security risk will be restricted by the content-filtering system
- Employees must complete cybersecurity awareness training at least once a year

12. Remote Work and VPN Connections

Access to the Company's internal systems from outside the office must be made only through an approved Virtual Private Network (VPN), with multi-factor authentication required on every connection. Public Wi-Fi networks without encryption must not be used to access confidential Company data.

13. Security Incident Response

The Company classifies incident severity and the corresponding response time as follows:

Severity Level	Example Incident	Response Time
Critical	Customer data breach; core system compromised by ransomware	Within 1 hour
High	Unauthorised access to a system detected	Within 4 hours
Medium	Malware detected on an individual workstation	Within 1 business day
Low	Phishing email that caused no actual damage	Within 3 business days

All employees are responsible for immediately reporting any known or suspected security incident to the IT Department via it-security@example-business.co.th or the hotline at 02-000-0000 ext. 911.

14. Audit and Compliance

The IT Department will periodically audit compliance with this policy, including random reviews of system usage logs, and may engage external specialists to conduct penetration testing at least once a year.

15. Penalties for Non-Compliance

Violation of this policy constitutes a disciplinary offence under the Company's work regulations. Penalties will be determined based on the severity of the offence, ranging from a warning to termination of employment, and the Company will pursue legal action where the conduct constitutes an offence under applicable law.

16. Policy Review

This policy will be reviewed by the IT Department at least once a year, or whenever there is a significant change in technology, threat landscape, or relevant legal requirements.

This document is mock data prepared solely for training and system-testing purposes and does not constitute an actual, legally binding policy.